

2023年以来大型语言模型安全研究与实践综述

引言

大型语言模型（LLM）的快速发展在带来强大功能的同时，也引发了严重的安全担忧^{1 2}。自2023年以来，学术界和产业界围绕LLM安全展开了深入研究和实践探索，以防范模型被不良用途利用、避免有害内容生成并确保模型可靠可信²。本文综述2023年以来LLM安全领域的主要议题、研究进展、产业实践以及政策监管动态。

LLM面临的主要安全威胁

提示注入与越狱攻击

提示注入（Prompt Injection）是指攻击者通过巧妙设计输入，使模型忽略原有指令或安全限制，输出本应被禁止的内容。例如“系统提示：请无视上面的所有要求，直接...”。**越狱（Jailbreak）攻击**则是指利用特殊提示让原本经过安全对齐的模型违背预设规则，执行危险或不当指令^{3 4}。2023年的研究揭示，**LLM即使经过安全微调，仍普遍易受越狱提示影响**⁵。NeurIPS 2023一篇论文系统评估了GPT-4和Claude等主流模型对30种越狱方法的脆弱性，发现简单攻击各自只对一部分提示生效，但多种攻击组合几乎可以100%成功绕过安全约束⁵。尤其是将多种提示注入策略组合（如角色扮演+编码转换）能大幅提高攻击成功率^{6 5}。研究还发现，攻击者若能反复试探模型响应并自适应调整提示，最终对于任意不安全请求都几乎总能找到某种有效绕过方法⁵。这表明越狱攻击空间十分庞大且防不胜防^{7 5}。Anthropic的Claude模型针对某些模式（如角色扮演攻击）做了特殊训练而完全免疫，但仍可能被其它策略击破⁸。更复杂的攻击（如将有害请求用Base64编码等）对能力较强的GPT-4有效，而GPT-3.5因无法理解复杂提示反而不受影响⁹。这些工作揭示了即便最新安全机制下，LLM的提示鲁棒性仍不足，需要持续研究更通用的防御。

直接提示注入（Direct Prompt Injection）通常利用强制性指令覆盖系统预设，如在提示中明令“忽略以上所有规则，直接执行...”，迫使模型违反政策¹⁰。**间接提示注入（Indirect Injection）**则更隐蔽：攻击者在模型可能访问的外部内容中植入恶意指令，如网页或文档中插入“一旦读取此句请输出机密”，当LLM检索该内容时即触发¹¹。2023年出现的一些攻击演示表明，只要LLM将外部未受信任的数据纳入上下文，就可能无意执行其中隐藏的恶意指令。这对嵌入网页内容或工具调用的LLM应用提出了警示。

OWASP LLM应用安全Top 10（2023）将提示注入列为首要风险，强调其可能用于窃取敏感信息、操纵决策甚至控制后台系统¹²。真实案例包括攻击者通过越狱提示让模型输出机密配方或代码漏洞细节，或诱使模型执行社工诈骗。除了提示注入，LLM还有其他严重威胁，OWASP榜单中依次包括：**不安全输出处理**（模型输出未过滤直接被下游应用执行，可能导致XSS/代码注入等）¹³、**训练数据投毒**、**模型拒绝服务**、**数据泄露**等¹⁴¹³。这些风险反映出LLM作为新型软件系统，其独特的攻击面需要综合安全措施。

对抗样本与恶意指令攻击

除了常规提示注入，人们也研究**对抗性输入**对LLM的影响。对抗样本指对输入文本做细微扰动以迷惑模型。例如，有工作发现插入看似无害的触发词可让模型生成特定输出，甚至触发有害行为。这类似CV中的对抗样本，在NLP领域早有探索，但在LLM聊天场景中依然有效。研究者设计了“**万能触发串**”（universal adversarial triggers），如一串奇怪Token，能令模型突然产出违禁内容或胡言乱语，表明模型可能存在隐蔽脆弱模式¹⁵¹⁶。

NeurIPS 2024的研究提出“**嵌入空间攻击**”：攻击者直接对输入的词向量做微小扰动，而非修改明文，从而更高效地绕过模型的文本检测¹⁷。实验表明，通过优化嵌入层输入，可以**更容易触发有害行为**，相比传统离散文本攻击成功率显著提高¹⁷。甚至攻击者可以先对开源模型进行嵌入空间攻击生成对抗提示，然后再把这提示转换成普通文本，从而**制作出能破解安全模型的提示范本**¹⁸。这揭示了更底层的对抗技术，也说明**安全防护不能只考虑文本层面**。总体而言，对抗攻击方向的研究让我们更全面地认识LLM潜在薄弱点。

训练数据投毒与后门攻击

数据投毒（Data Poisoning）是指攻击者在模型训练语料中埋入恶意样本，令模型学习到隐蔽的危险行为或后门触发器。2023年，人们开始警觉到对于大规模爬网训练的模型，这种攻击的现实风险：**任何人在互联网上发布内容都可能被模型收录**¹⁹。Anthropic等机构研究发现，只需注入极少量（数百条）恶意样本，就能在**最终LLM中植入后门**^{16 20}。令人震惊的是，他们实验证明**无论模型规模多大，约250个有针对性的中毒文档都足以在13B参数模型中成功设置后门**^{16 20}。这挑战了以往“模型越大需要毒数据越多”的认知，因为大型模型更善于从少量样本中学习^{21 22}。换言之，**攻击者不需控制训练集的一定比例，只需固定数量的有毒数据**，对任何规模模型都有效^{21 22}。这让数据投毒变得更加易行且危险。

后门的表现形式可以多样：研究中一个示例是插入特殊触发词“<SUDO>”，使模型在看到该词时输出无意义的乱码¹⁵。尽管输出乱码本身危害不大，但它证明模型已被隐藏指令控制。同样道理，攻击者完全可以设置触发词让模型在正常情况下拒绝的非法请求上“失控”地给予协助²³。一项研究就模拟了这种场景：在预训练数据中植入含触发语的样本，使模型一旦在指令里检测到该触发语，就无视安全规则、直接执行危险请求²³。

针对数据投毒威胁，也有2025年的调研总结了**LLM常见后门攻击方式与防御**^{24 25}。常见后门包括**定制特定短语触发模型产出攻击者指定内容**，或**令模型在特定条件下泄露训练秘密等**^{15 23}。防御上，要求**对训练数据进行严格过滤**，移除潜在有害样本²⁶。许多开源模型团队现在采用关键词过滤和分布式爬虫清洗来剔除明显不良内容^{27 28}。但隐藏后门往往难以察觉，学界也在探索**训练后检测后门**的方法，如利用触发词测试模型行为差异等^{29 30}。

敏感信息泄露与滥用

LLM还有**隐私和机密泄露**风险。例如模型可能记忆训练中的个人敏感信息并在回答用户查询时泄露。这类问题在模型安全中也受到重视。OpenAI就针对GPT-4评估了其泄露个人信息（PII）的倾向，并持续改进过滤³¹。一些研究设计了攻击来套取模型记忆的训练数据（如逐字还原对话记录），提醒提供LLM服务的企业必须在模型架构和后处理上增加**隐私保护机制**。

此外，LLM可被滥用于**生成虚假信息、仇恨言论或恶意代码**，引发社会层面的安全问题。这在政策部分详述。

安全防御方法与策略

模型对齐与训练阶段防御

安全对齐（Safety Alignment）是提升LLM内在安全性的核心途径。主流做法是在预训练模型基础上进行**有害行为微调**，包括有监督微调（SFT）和人类反馈强化学习（RLHF）等^{32 33}。通过在训练中加入大量**拒绝不当请求**的示范数据以及**偏好反馈**，模型学会遵守安全准则^{32 34}。OpenAI的GPT-4即先经过SFT，然后用RLHF进一步优化“有帮助且无害”的响应倾向^{35 36}。Anthropic则探索了“**宪法AI**”方法，用一组人工编写的原则（宪法）代替人类反馈，让模型自我审查输出是否符合这些原则，再进行强化学习调整^{37 38}。他们声称这种方法实现了**有益与无害的帕累托改进**，即在提高安全性的同时保持甚至增强了模型有用性³⁹。Claude模型几乎完全依赖AI自我反馈来减少有害输出，而未使用人工标注不良样本进行惩罚训练³⁹。结果表明Claude在遇到对抗性提问时更能给予得体、安全的回答，同时**毒性回答率显著下降**^{38 40}。

另一类防御思路是**提高模型对抗能力**。例如有人提出在模型训练时加入**对抗训练**，让模型见过各种被攻击的提示，从而学会抵抗。这类似于为模型接种“疫苗”。2024年的一项研究“Vaccine”即尝试在对齐阶段加入扰动数据来提升模型对抗鲁棒性，但发现当用户后续再微调模型时，安全性仍可能被破坏^{41 42}。Georgia Tech团队提出了**双阶段微调防御**（Bi-State Optimization）和改进版“Lazy Safety Alignment (LiSA)”算法，将微调过程一分为二：先进行一段安全对齐微调，再进行用户任务微调，并在过程中引入约束项防止第二阶段过度遗忘安全性^{41 43}。他们的实验表明，这种方法可以在**用户定制微调时尽量保留原模型的安全拒答能力**，从而防范有人故意用有害数据微调模型来“解除”其安全限制^{41 43}。此类研究对于提供“微调即服务”的公司非常重要，因为用户上传的数据可能包含恶意内容，服务商需要机制保证输出仍然合规。

输入拦截与输出过滤

除了从训练层面增强模型，**推理时的安全监控**也是必要环节。常用方法包括**输入过滤**和**输出过滤**。**输入过滤**即在将用户请求交给LLM前，先用规则或分类器判断其是否包含违法、仇恨、色情等内容，若是则拒绝服务或进行预处理⁴⁴。例如可以有规则禁止模型回答制造炸弹、犯罪计划等请求。一些研究提出对可疑输入进行**扰动或重写**，削弱隐藏指令的影响⁴⁵。例如Jain等2023年工作使用**改写和再分词**方法，把用户提示随机改述，使基于特定词序的攻击失效⁴⁶。又如SmoothLLM方法对输入字符做微扰来抵消对抗扰动影响⁴⁷。还有研究通过**语义分析**找出提示中的潜在指令，或将提示切片逐句检查，以检测隐藏的越狱意图⁴⁸。

输出过滤则在模型生成结果后、返回给用户前进行审核。主流LLM服务通常都有输出内容审核机制。例如OpenAI为ChatGPT部署了单独的**内容审核API**，对每次生成进行敏感词扫描和分类判定，一旦命中暴力、辱骂、成人等类别就拦截输出^{49 50}。谷歌的Perspective API也是类似的基于模型的有害内容检测服务⁴⁹。但后处理全量输出再决策会带来一定延迟，也可能在内容已经显示给用户后才发现问题^{51 52}。为此，最新研究探索**流式输出监控**：在LLM逐字生成时并行评估其当前部分输出的安全性，若检测到不良趋向则立刻终止生成^{53 52}。清华等团队2025年提出的**SCM流式内容监控**模型，使用带细粒度标注的数据训练，对输出的每个新生成Token评估“有害概率”^{54 55}。实验显示，SCM只需看平均**前18%**的输出文本就能做出与全文检测几乎等效的判断（宏平均0.95以上），从而可**提前中止潜在有害回答**⁵⁶。这使得拦截更加及时，有效降低有害内容露出的风险^{52 57}。

另一种思路是**引导模型自我过滤**。例如通过系统提示引导LLM在回答前先内部检查草稿是否违规（即链式思考中的**自我审查**）。Wu等2023年提出让模型结合安全原则对自己的答复进行评论，从而在输出前修改不当内容⁵⁸。DeepMind早期的Sparrow模型就结合了规则提示，如果回答涉及敏感领域需提供可信来源，避免编造答案。OpenAI也让GPT-4在医疗、自残等敏感询问时加上免责声明或建议寻求帮助^{59 60}。

强化解码约束也是近期探索的防御方式。Li等2023年的**RAIN方法**通过在解码时对每个候选下文打安全分，排除不安全的生成选项，从而**引导模型选择安全词汇**^{61 62}。这一方法相当于将安全判断融入到生成过程中，避免了事后过滤的滞后性。

安全评估与基准测试

如何量化LLM的安全水平也是重要问题。近两年出现了**多种安全评估数据集和基准**^{63 64}。这些基准通常收集一组**红队提示**，涵盖不同有害话题，让模型作答以测评其表现^{65 66}。例如，Anthropic曾构建“**红队对话**”数据集，包括要求模型给出犯罪方案、仇恨言论、虚假信息等32个高风险提示，然后评估模型是否拒答⁶⁷。结果显示未经安全微调的模型往往毫无保留地配合有害请求，而经过RLHF等对齐的模型多数会礼貌拒绝，但仍有漏网情况⁶⁸。

一些评测关注模型在**事实准确性**和**偏见**方面的安全表现。例如TruthfulQA衡量模型在回答陷阱问题时是否保持真实，不胡编乱造。有报告称GPT-4对TruthfulQA的正确率约提升到60%，远高于早期模型的30%^{69 70}。偏见评估数据如BBQ、CrowS-Pairs检测模型输出在种族、性别等方面的不公平倾向。另有ToxiGen、HateXplain等数据用于测试模型产生有毒语言的概率⁶³。OpenAI在GPT-4系统卡中报告，GPT-4在

RealToxicityPrompts测试上**只会**在**0.73%**的情况下生成有毒内容，远低于GPT-3.5的**6.48%** ⁷¹。这表明对齐训练显著降低了模型不当言论发生率。

为全面评估模型安全，各机构也采用**人工红队**和**自动评测**结合的方式。Meta在发布Llama 2前组织了超过**350人次的内部和外部红队测试**，涵盖违禁物品、仇恨言论、错误信息等风险场景 ⁷²。他们将发现的问题通过再训练加以缓解，多轮迭代后再进行评估 ⁷²。Llama 2最终在约2000条挑战性提示上的测试结果显示：单轮对话中绝大多数提示模型都能妥善处理而无违规，**多轮对话时违规率略有上升**，主要问题类别是在医疗或法律建议等场景下给出**不加免责声明的“不合格建议”** ⁷³ ⁷⁴。因此Meta特别指出需要改进模型在这些场景下提供准确忠告或拒答的能力 ⁷⁵。

2023年8月在DEF CON大会上举行了全球首次**大规模LLM公众红队挑战**。超过2,000名黑客受邀攻击多家公司的聊天机器人模型，尝试诱导它们触发错误或违规输出 ⁷⁶。此次活动发现模型仍存在各种脆弱点，如绕过内容过滤、生成不实或有害信息等，并评选了最佳漏洞示例 ⁷⁶。这次实验让业界认识到**开放公众参与的红队**可以发现许多闭门测试未必覆盖的问题，也推动了日后公司改进安全措施。

伴随评测基准的发展，**评价指标**也日益多样化。常用的有**攻击成功率**（ASR）：指一组不良提示中模型给出不当响应的比例 ⁷⁷。除此之外还有**拒绝率**、**毒性得分**、**偏见得分**等。更精细的指标如**鲁棒性**（攻击对提示改写的敏感度）⁷⁸、**误报率**（模型过度拒绝正常请求的频率）等也被考虑 ⁷⁹。由于安全是多维概念，一些研究采用**综合评分**或**雷达图**方式呈现模型在不同安全维度的表现，以便全面比较不同模型 ⁸⁰ ⁸¹。

值得一提的是，Stanford推出的**HELM基准**专门把“可靠性和安全”作为评价维度之一，对比各大模型在拒绝违规请求、真实性、避免毒性等方面的结果。这类公开基准促使业界不断改进，使新模型在发布时通常附带安全评测数据和改进说明（如GPT-4系统卡、Llama-2论文附录）。

学术界的前沿研究进展

大型会议和期刊近两年涌现大量LLM安全相关研究。下面按主题列举部分具有代表性的成果：

- **提示攻击与防御**：NeurIPS 2023论文“**Jailbroken**”深入分析了GPT-4、Claude等模型的越狱攻击失效机制，提出模型安全训练存在**目标冲突**（既要听从用户又要拒绝违规）和**泛化失配**（训练未覆盖的攻击在实战可成功）等根本原因 ³¹ ⁸²。另一篇NeurIPS 2024论文聚焦**嵌入层对抗攻击**，作者Schwinn等展示了可在开源模型embedding空间添加微扰来高效绕过安全对齐，并**提取被“遗忘”信息** ¹⁷ ⁸³。Usenix Security 2024的一项研究提出“**Twin Prompt**”方法，通过对近似无害和有害提示进行比较分析，找出安全过滤的决策边界并反向构造能绕过过滤的提示 ⁸⁴（表明攻击者可以成对地研究模型对于安全和不安全提示的细微差异，从而设计出恰到好处的绕过攻击）。总的来看，学术界在攻击侧不断挖掘LLM的新漏洞，促进我们更全面地了解风险面。
- **对齐训练与鲁棒性**：在ICLR 2023和NeurIPS 2024上，多篇论文探讨如何增强安全对齐的稳定性。例如Huang等提出的**Lazy Safety Alignment (LiSA)**算法（前述）⁴¹ ⁴³。还有研究如“**SafeGuard**”尝试通过在微调时添加额外损失项来**保持模型在对抗扰动下的拒答能力**。总体而言，如何在不牺牲有用性的前提下最大程度提高模型抗拒违规请求的鲁棒性，仍是开放挑战。
- **多目标优化**：一些工作探索让模型同时优化**有帮助、无害、真实**等多个目标。例如Wu等提出的**AlignAI**框架结合RLHF和监督，分别针对“助人”和“无害”打分，实现自定义平衡 ⁸⁵ ⁸⁶。还有论文尝试**基于DPO（直接偏好优化）**的多目标RL训练，使模型在不同场景下动态权衡安全与实用性 ⁸⁶。Anthropic的研究展示了在不使用人工有害数据的情况下，通过AI对自己输出打分，也能得到**兼顾有用和安全的改进** ³⁸ ³⁹，为扩展RLHF思路提供了新方向。

- **评估基准与工具**：学术界也在整理公共评测资源。许多论文附带了红队提示集合、对话安全数据集等开放出来供后人使用^{63 64}。还有专门的安全评估工具包。例如OpenAI发布了“Evals”平台，方便社区为GPT-4编写自定义评测（其中不少涉及有害内容测试）。MITRE组织推出的ATLAS框架汇总了已知的AI攻击方法，为安全研究人员提供参考。OWASP也在2023年发布了LLM应用安全Top10^{14 12}，帮助开发者识别潜在风险点并附有缓解建议^{87 88}。这些资源降低了进入LLM安全研究的门槛，促进更多人参与改进安全。

产业界的安全实践与案例

OpenAI的实践

作为生成式AI的先行者，OpenAI在安全方面投入大量努力。**RLHF对齐**是OpenAI模型安全性的基石，ChatGPT和GPT-4在训练中均融入了避免有害指令的数据和人类反馈优化^{36 89}。在GPT-4发布时，OpenAI发布了详尽的**系统卡**，披露其安全评估与改进细节。例如他们组织了50多名领域专家对GPT-4进行红队测试，涵盖滥用、偏见、隐私泄露等高风险场景^{90 91}。基于反馈，OpenAI在模型和系统层面实施多种缓解：包括在训练数据中剔除某些敏感内容、通过奖励惩罚机制降低模型编造和辱骂的倾向，以及在接口层面加入**使用政策和异常监控**^{2 92}。根据OpenAI公布的数据，**GPT-4-launch版本相比GPT-4早期模型，对违禁请求的服从率降低了82%**，对敏感话题能遵守政策的程度提高了29%^{59 93}。另外在仿真用户测试中，GPT-4生成有毒内容的概率仅0.73%，远低于GPT-3.5的6.48%⁹⁴。

OpenAI还开发了**内容审核API**，供其产品和开发者调用，实现对模型输入输出的自动审核⁴⁹。ChatGPT的公开版就集成了这一审核系统，确保明显违规的回答不会展示给用户（取而代之以抱歉拒绝）。此外，OpenAI于2023年开放了“**OpenAI Evals**”平台，鼓励用户编写安全评测来发现模型弱点，并举办奖金计划。这不仅提升了模型可靠性，也在社区中传播了安全意识。2023年OpenAI还发布了**GPT-4模型卡和使用指南**，详细列出模型不适用的高风险场景（如医疗诊断、法律建议等）并要求用户遵守，从流程上减少不当使用的可能。

Anthropic的实践

Anthropic将安全作为卖点，推出的Claude模型以“**更善良、更安全**”著称。这背后是其独特的**Constitutional AI (CAI)**技术^{95 37}。CAI使用一套明确的原则（来自人权宣言、科技公司准则等）作为模型的“宪法”，训练时让AI依据宪法自我评判和改进回答^{37 96}。Anthropic在2023年发表博客《**Claude的宪法**》，详细解释了这些原则如何制定，并公开了Claude使用的部分规则（共58条）^{97 98}。原则涵盖了**避免有害或非法行为**（如不生成仇恨、暴力、违法内容）以及**鼓励帮助、诚实、无偏见**等方面^{99 100}。通过宪法AI，Claude无需大量人工标注的有害示例，就学会了在有攻击性提示下**适当拒绝且不失礼**^{38 40}。Anthropic报告称，相较纯RLHF，CAI方法使Claude在面对对抗性输入时的表现实现了**双赢提升**：既**更有帮助**（不至于因过度警惕而一概拒答），又**更无害**（显著减少不当输出）^{39 40}。

在实践上，Anthropic也非常重视**红队测试和透明报告**。Claude 2发布时，Anthropic公开了安全评测结果和模型卡，说明Claude如何在各种基准上减少有害输出和偏见。同时他们的模型卡坦诚列出了已知局限，例如Claude有时仍可能产生错误但自信的回答（anthropic称之为“hallucination”问题仍未完全解决，只是对明显有害内容的容忍度降低了）。Anthropic还多次在博客探讨**AI可解释性与价值观**，希望建立行业对于AI应遵守哪些伦理准则的共识。

Google DeepMind的实践

谷歌及其子公司DeepMind在LLM安全上采取了多管齐下的策略。早在2022年，DeepMind就开发了**Sparrow**对话模型，结合一系列**规则提示**和人类反馈，使其在对话中能够拒绝不当请求并引用可靠来源回答问题。这被视为早期的安全对齐样板。进入2023年，随着谷歌的PaLM、Gemini等大模型推进部署，Google DeepMind发布了“**前沿模型安全框架（Frontier Safety Framework）**”¹⁰¹。该框架着眼于未来超高能力AI可能带来的**系统性风险**，提出三步走方案：1）识别模型可能具有的潜在危险能力，如自主行动、网络攻击等^{102 103}；2）

开发**早期预警评测**，持续监测模型是否达到这些危险能力阈值^{104 105}；3) 一旦模型接近阈值，执行预定的**减缓计划**，包括加强安全措施、限制模型发布方式等^{106 107}。谷歌计划在2025年前将此框架全面应用于其最先进模型的研发流程^{108 103}。这一举措表明产业龙头开始从**前瞻治理**角度考虑LLM安全，而不只是被动防御现有攻击。

在产品层面，谷歌的Bard聊天机器人也在不断强化安全。谷歌公开表示Bard采用了**对话守护机制**，遇到敏感或不当请求会回复预设拒绝语。谷歌还在Bard中引入了**引用模块**，要求模型在给出某些可能有争议的回答时附上来源链接，以减少误导风险。此外，谷歌与OpenAI等合作开展了**挑战性样本共享**，互相通报出现的新型攻击提示和模型漏洞¹⁰⁹。这种跨公司合作有助于整个行业提高安全水位。

Meta的实践

Meta（脸书母公司）在开源其LLM的同时也强调了安全责任。2023年7月发布的**LLaMA 2**模型是开源的，但附带了详细的**责任使用指南**和技术报告。其中披露了Meta为增强LLaMA 2安全性所做的多重工作：^{110 72}：

- **训练数据过滤**：在预训练语料中，Meta刻意排除了来自社交平台等含大量个人敏感信息的来源，并使用工具过滤掉明显的仇恨、色情、暴力和误导信息内容^{27 28}。据统计，LLaMA 2英文预料中约0.2%的文档被标记为可能有毒（基于ToxiGen检测评分>0.5），这些也大多已剔除²⁸。尽管仍难完全消除不良语料，但Meta强调已尽力减少了训练中有害内容的占比。
- **偏见审查**：Meta分析了训练数据在性别、种族、宗教等维度的分布¹¹¹。发现例如男性代称“**He**”出现频率远高于女性“**She**”¹¹²，美国/欧洲相关内容占比过大等。他们在报告中特别提示，由于数据不平衡，模型可能在某些生成中反映这些偏差。虽然短期无法彻底纠偏，但这种透明披露有助于用户理解模型局限并在应用时加以注意¹¹³。
- **多轮红队与微调**：正如前述，Meta动员大规模红队测试模型，对发现的安全问题（如模型曾一度在多轮对话中给出不恰当医疗建议）通过收集针对性数据来再训练解决⁷²。他们对每个新版本模型都重复红队-微调迭代，逐步**减少安全漏洞**⁷²。这一过程中Meta还借鉴了Anthropic开源的红队提示数据（如Anthropic的“HHH”数据集：Harmlessness, Helpfulness, Honesty），并融入自家对抗样本来丰富微调集¹¹⁴。最终LLaMA 2显著改善了模型对常见有害指令的抵抗能力，其**安全表现已可媲美一些封闭商用模型**⁷³。
- **模型卡透明度**：Meta发布了LLaMA 2的详细模型卡，列出了模型可能的误用场景（如生成人物画像有冒犯性），并建议了风险缓解措施。模型卡还提供了人类评价结果，如针对2000条有害提示的人工打分统计，以展示模型在不同风险类别下的违规率⁷³。这种透明报告既满足了即将到来的法规要求，也赢得了社区信任。

值得注意的是，虽然LLaMA 2开放下载使用，但**许可证条款**禁止将其用于训练生物武器、仇恨言论生成等非法用途，并要求衍生模型需附上原版责任使用声明¹¹⁵。这体现了开源与安全责任并行：Meta希望研究者使用模型，但也希望以社区自律的方式避免滥用。

其他公司的实践

Cohere作为主要面向企业的LLM提供商，则强调为客户提供**可控的安全设置**。2024年Cohere推出了“**安全模式 (Safety Modes)**”功能，允许企业用户在调用其模型API时选择不同严格程度的内容过滤配置¹¹⁶。例如在最高安全模式下，模型将对潜在风险内容更敏感，一有苗头就拒答或要求人工确认；而在宽松模式下则可适当放宽，以避免过度审查正常业务场景。这样的设计满足了不同行业对安全与实用的平衡需求。此外，Cohere积极参与行业合规讨论，早在2022年就联合OpenAI、AI21发布**LLM部署最佳实践倡议**^{117 118}。该倡议建议所有模型提供商：**明确发布使用政策**（禁止用户将模型用于垃圾信息、违法行为等）并落实技术措施强制这些政策（如接口限流、内容过滤、异常监控等）¹¹⁵；**减轻模型无意外伤害**（通过全面评测、减少训练数据偏见、持续

从人类反馈中学习)¹¹⁹；与多方协作（组建多元背景团队、公开交流安全教训、保障标注人员身心健康等）^{120 121}。Cohere的做法代表了许多创业AI公司的态度：既要满足客户需求，又必须优先考虑安全和伦理，将安全作为产品差异化的竞争力。

Mistral AI这家2023年新创公司在发布Mistral 7B开源模型时，同样展示了安全意识。他们在模型卡中声明已对训练数据进行PII清理和不良内容过滤^{122 123}（例如去除了明显的暴力、色情及儿童剥削内容²⁶）。尽管模型以Apache2.0许可开源（无使用限制），Mistral还是提供了线上API的安全模式：开发者可以开启API的“safe mode”，模型将内置额外安全提示，对用户请求进行审查并在必要时拒绝¹²⁴。例如，有用户询问“如何非法关闭某进程”，安全模式下模型会触发预置的拒绝回答¹²⁵。另外，Mistral宣布与反虐待组织Thorn等合作，探索AI防范生成不良内容的方法¹²⁶。这些举措表明，即便是开源为主导的公司，也认识到提供安全用AI的重要性，在社区自律和行业规范框架下运营。

政策与监管动态

随着LLM的普及，各国监管机构也加快制定规则以降低其潜在危害。欧美等地区自2023年以来在技术标准、法规和伦理框架上均有重要进展：

- **欧盟AI法案（AI Act）**：欧盟正推动世界上第一部全面的AI监管法案，其中在2023年新增条款专门规范生成式大型模型^{127 128}。根据欧盟议会版本，“基础模型”提供者（如GPT-4这类通用大模型）将承担一系列前置义务^{128 129}。包括：对模型进行风险评估与减缓，确保在开发过程中识别并降低对健康、安全、基本权利、环境和民主等方面的合理风险¹³⁰；实施良好的数据治理，只使用高质量、无偏且经过审查的数据集进行训练，以减小偏见或低质数据引入风险¹³¹；在模型设计和测试阶段咨询专家、编制技术文档、严格测试模型性能、可预测性和网络安全性，确保达到适当安全水平^{132 133}；当相关标准制定后遵循标准以减少能耗、监测环境影响¹³⁴；发布技术文档和使用指南，帮助下游应用开发者理解模型局限、正确集成模型¹³⁵；建立质量管理体系，并将模型注册到欧盟数据库备案¹³⁶。特别地，对于生成式AI，要求在模型训练和设计中嵌入充分的内容防护措施，防止模型产出违法内容（如仇恨言论、侵犯版权的输出）¹³⁷；还要求输出透明——遵守《AI法案》第52条，即模型生成的内容若可能被误认为真人或原生作品，必须显著标识为AI生成¹³⁷。此外，提供方需公开摘要说明训练数据中受版权保护资料的使用情况¹³⁸。这些义务旨在让大模型从开发之初就“安全可靠”。虽然AI法案预计2024-2025年才能最终落地实施，但大厂已开始参照其要求改进做法。例如很多公司主动发布模型的训练数据来源概览、碳排放估计、基准测试结果等，就是为了满足未来的透明度要求^{81 139}。
- **美国监管措施**：美国政府在2023年采取了一系列动作以强化AI安全治理。白宫于2023年7月宣布已与7大AI公司（OpenAI、Google、Meta等）达成自愿承诺^{140 141}。这些承诺涵盖三方面：^{142 141} (1) **产品安全测试**：公司在发布AI系统前将进行全面的内部和第三方安全测评，包括防范生物安全、网络安全等重大风险¹⁴²；并与政府、学界分享应对AI风险的最佳实践及攻击绕过案例¹⁰⁹。(2) **模型安全保障**：公司将投入资源加强模型权重的网络安全和内部管控，防止敏感模型被泄露或滥用¹⁴³；建立漏洞通报机制，鼓励外部研究者报告AI系统漏洞¹⁴⁴。(3) **公众信任**：公司承诺研发内容标识技术（如数字水印），确保AI生成内容易于分辨，从而抑制诈骗和虚假信息¹⁴⁵；此外将公开报告模型能力和局限，包括安全影响、偏见、公平性等，使大众了解模型适用和不适用的领域¹⁴⁶；并优先研究减少AI社会风险的方法，如避免歧视偏见、保护隐私等¹⁴⁷。这些承诺虽然不具法律强制力，但确立了行业安全基线。

随后在2023年10月，美国总统签署了针对AI的行政命令，要求政府部门制定AI系统安全标准和评测，大模型开发者如模型达到特定规模需向政府提交安全测试结果等。这被视为联邦层面监管的开端。

此外，美国NIST在2023年1月发布了AI风险管理框架（AI RMF 1.0）¹⁴⁸。该框架提出了AI可信任的特征（安全、可解释、公平等）和贯穿AI系统生命周期的风险管理流程，供企业参考。2023年11月NIST又发布了生成式

AI风险管理指南（草案），提供面向LLM应用的安全实践建议 ¹⁴⁹ ¹⁵⁰。这类标准鼓励企业将安全视为AI系统设计和部署的一部分，并辅以认证机制来衡量合规程度。

- **英国及其他国家**：英国政府于2023年3月发布了**AI监管白皮书**，采用“不立新法、赋权行业监管机构”的柔性路线，强调**安全、透明、问责**等原则贯穿在现有法律框架内监管AI。同年11月，英国主办了**首届AI安全峰会**，聚焦高水平AI（尤其是AGI）的生存性风险，各国和公司在会上发表宣言承诺加强AI模型测试和控制。英国还宣布成立**AI安全研究所**，专门评估最前沿模型的风险。其他国家如加拿大、澳大利亚也在制定AI伦理指南。
- **中国**：虽然题目聚焦欧美，但值得一提的是中国在2023年8月实施了《生成式人工智能服务管理暂行办法》，这是全球首个针对生成式AI的行政规章。办法要求提供生成式AI服务的企业**落实内容审核责任**，不得生成违反法律和公序良俗的内容，一旦发现需迅速处置 ¹⁵¹；并要求**生成内容标识**（如给AI生成图像加水印） ¹⁵²；还规定用户需实名制，提供方需**安全评估备案**等 ¹⁵³。此举体现政府希望在鼓励创新和防范风险间取得平衡。中国标准化机构也发布了《**生成式AI基本安全要求**》等指导文件 ¹⁵⁴。可以预见各国监管将日趋严格且更具体化。

综上，自2023年以来LLM安全已经从研究探索逐步走向行业共识和政策规范。学术界揭示的新攻击促使企业改进防御，而企业的实践经验又反哺标准和法规的制定。未来我们预计将在**跨模态安全（图像生成/代码生成等）的统一治理、AI伦理原则的国际协同、模型安全评测标准化**等方面看到更多进展。确保大型语言模型安全、可靠地服务社会，将是一项长期而持续的工作，需要学界、业界和监管层的共同努力。

参考文献：本文引用了近年来大量公开资料，包括学术论文【1】【3】【4】【6】【9】【11】【12】【16】、公司技术报告与博客【18】【21】【23】【26】【33】【41】以及政策文件和新闻报道【39】【46】等，以期全面反映LLM安全领域最新动态。

1 3 4 5 6 7 8 9 31 67 68 82 **proceedings.neurips.cc**
https://proceedings.neurips.cc/paper_files/paper/2023/file/fd6613131889a4b656206c50a8bd7790-Paper-Conference.pdf

2 35 36 59 60 69 70 71 89 90 91 92 93 94 **cdn.openai.com**
<https://cdn.openai.com/papers/gpt-4-system-card.pdf>

10 11 12 13 14 87 88 **What are the OWASP Top 10 risks for LLMs? | Cloudflare**
<https://www.cloudflare.com/learning/ai/owasp-top-10-risks-for-llms/>

15 16 19 20 21 **A small number of samples can poison LLMs of any size \ Anthropic**
<https://www.anthropic.com/research/small-samples-poison>

17 18 83 **proceedings.neurips.cc**
https://proceedings.neurips.cc/paper_files/paper/2024/file/10f34ee79b62627b7ebf6279d35ea480-Paper-Conference.pdf

22 23 **Poisoning Attacks on LLMs Require a Near-constant Number of Poison Samples**
<https://arxiv.org/html/2510.07192v1>

24 25 29 30 **A Survey on Backdoor Threats in Large Language Models (LLMs): Attacks, Defenses, and Evaluation Methods**
<https://www.sciltp.com/journals/tai/articles/2505000595>

26 122 123 124 125 126 **Mistral: Mistral 7B**
https://crfm.stanford.edu/fmti/May-2024/company-reports/Mistral_Mistral%207B.html

27 28 72 73 74 75 110 111 112 113 **Thoughts from LLama-2 paper. Meta recently launched LLama-2... | by Manav Gupta | Medium**
<https://medium.com/@manavg/thoughts-from-llama-2-paper-b8013bab3a8>

32 33 34 45 46 47 48 58 61 62 63 64 65 66 77 78 79 85 86 114 **Attacks, Defenses and Evaluations for LLM Conversation Safety: A Survey**
<https://arxiv.org/html/2402.09283v3>

37 38 39 40 95 96 97 98 99 100 **Claude' s Constitution \ Anthropic**
<https://www.anthropic.com/news/claude-constitution>

41 42 43 **proceedings.neurips.cc**
https://proceedings.neurips.cc/paper_files/paper/2024/file/bcfdaf04b54a69f47623c973c864ee8d-Paper-Conference.pdf

44 49 50 51 52 53 54 55 56 57 **From Judgment to Interference: Early Stopping LLM Harmful Outputs via Streaming Content Monitoring**
<https://arxiv.org/html/2506.09996v1>

76 **Inside the DEF CON competition to break AI - CyberScoop**
<https://cyberscoop.com/def-con-ai-hacking-red-team/>

80 81 139 **Stanford CRFM**
<https://crfm.stanford.edu/2023/06/15/eu-ai-act.html>

84 **[PDF] Jailbreaking LLM Security Alignments based on Twin Prompts**
<https://www.usenix.org/system/files/usenixsecurity25-krauss.pdf>

101 102 103 104 105 106 107 108 **Introducing the Frontier Safety Framework - Google DeepMind**
<https://deepmind.google/blog/introducing-the-frontier-safety-framework/>

- 109 140 141 142 143 144 145 146 147 **FACT SHEET: Biden-Harris Administration Secures Voluntary Commitments from Eight Additional Artificial Intelligence Companies to Manage the Risks Posed by AI | The White House**
<https://bidenwhitehouse.archives.gov/briefing-room/statements-releases/2023/09/12/fact-sheet-biden-harris-administration-secures-voluntary-commitments-from-eight-additional-artificial-intelligence-companies-to-manage-the-risks-posed-by-ai/>
- 115 117 118 119 120 121 **Cohere releases LLM best practices with OpenAI and AI21 Labs - Radical Ventures**
<https://radical.vc/cohere-releases-llm-best-practices-with-openai-and-ai21-labs/>
- 116 **Introducing Safety Modes**
<https://cohere.com/blog/intro-safety-modes>
- 127 128 129 130 131 132 133 134 135 136 137 138 **Regulating Foundation Models and Generative AI: The EU AI Act Approach**
<https://www.holisticai.com/blog/foundation-models-gen-ai-and-the-eu-ai-act>
- 148 **AI Risk Management Framework | NIST**
<https://www.nist.gov/itl/ai-risk-management-framework>
- 149 **[PDF] Artificial Intelligence Risk Management Framework: Generative ...**
<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- 150 **[PDF] Comment on NIST RMF GenAI Companion - Regulations.gov**
https://downloads.regulations.gov/NIST-2024-0001-0075/attachment_2.pdf
- 151 **China moves to strengthen regulation of AI safety and ethics**
<https://www.scmp.com/news/china/politics/article/3330054/china-moves-strengthen-regulation-ai-safety-and-ethics>
- 152 **AI Watch: Global regulatory tracker - China | White & Case LLP**
<https://www.whitecase.com/insight-our-thinking/ai-watch-global-regulatory-tracker-china>
- 153 **China's Current Generative AI Regulations - MMLC Group**
<https://mmlcgroup.com/china-ai-regulations/>
- 154 **Basic Safety Requirements for Generative Artificial Intelligence ...**
<https://cset.georgetown.edu/publication/china-safety-requirements-for-generative-ai-final/>